Penetration Testing Report

Engagement Overview

- **Engagement Type:** IDS/IPS Evasion & Network Enumeration Testing
- **Client Objective:** Validate effectiveness of IDS/IPS and firewall filtering improvements
- **Testing Environment:** Protected network (IDS/IPS enabled)
- **Assessment Scope:** Port scanning, service enumeration, IDS/IPS evasion testing

Executive Summary

We tested the organization's network security systems to see how well they can detect and block scanning and attack attempts.

In the first test, several services were openly accessible, allowing easy discovery of system information. After security improvements were made, filtering became stricter, but we were still able to bypass some protections and discover hidden services using alternative scanning techniques.

In the final test, we successfully identified a critical database service along with its version, showing that sensitive services are still discoverable despite security controls.

Overall, while improvements were made after each test, attackers would still be able to gather important system information and potentially find weaknesses.

Phase 1: Initial Network Discovery

Objective

Identify open ports and running services in an unfiltered environment.

Command Used

nmap -sS -Pn -n 10.129.2.80 --disable-arp-ping -F

Findings

Open TCP ports identified:

- 22/tcp (SSH)
- 80/tcp (HTTP)
- 110/tcp (POP3)
- 139/tcp (NetBIOS)
- 143/tcp (IMAP)
- 445/tcp (SMB)

Service Enumeration

Version scanning on ports 22, 80, and 445 revealed service details and possible OS fingerprinting.

Impact

- Multiple exposed services
- Easy reconnaissance possible
- System fingerprinting achievable

Evidence

```
┌──(root㉿kali)-[/home/mehdi/nmap_enum_lab]
└─# nmap -sS -Pn -n 10.129.2.80 --disable-arp-ping -F -oA fast_port_scan
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-19 06:57 EDT
Nmap scan report for 10.129.2.80
Host is up (0.77s latency).
Not shown: 94 closed tcp ports (reset)
PORT    STATE SERVICE
22/tcp  open  ssh
80/tcp  open  http
110/tcp open  pop3
139/tcp open  netbios-ssn
143/tcp open  imap
445/tcp open  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 2.93 seconds

┌──(root㉿kali)-[/home/mehdi/nmap_enum_lab]
└─#
```

```
Service scan sending probe NULL to 10.129.2.80:445 (tcp)
NSOCK INFO [2.1860s] nsock_read(): Read request from IOD #3 [10.129.2.80:445] (timeout: 6000ms) EID 42
NSOCK INFO [2.1860s] nsock_trace_handler_callback(): Callback: CONNECT SUCCESS for EID 8 [10.129.2.80:22]
Service scan sending probe NULL to 10.129.2.80:22 (tcp)
NSOCK INFO [2.1860s] nsock_read(): Read request from IOD #1 [10.129.2.80:22] (timeout: 6000ms) EID 50
NSOCK INFO [2.7120s] nsock_trace_handler_callback(): Callback: READ SUCCESS for EID 50 [10.129.2.80:22] (41 bytes): SSH-2.0-OpenSSH_7.6p1 Ub
untu-4ubuntu0.7..
Service scan hard match (Probe NULL matched with NULL line 3560): 10.129.2.80:22 is ssh.  Version: |OpenSSH|7.6p1 Ubuntu 4ubuntu0.7|Ubuntu L
inux; protocol 2.0|
NSOCK INFO [2.7120s] nsock_iod_delete(): nsock_iod_delete (IOD #1)
NSOCK INFO [7.9740s] nsock_trace_handler_callback(): Callback: READ TIMEOUT for EID 34 [10.129.2.80:80]
Service scan sending probe GetRequest to 10.129.2.80:80 (tcp)
NSOCK INFO [7.9740s] nsock_write(): Write request for 18 bytes to IOD #2 EID 59 [10.129.2.80:80]
NSOCK INFO [7.9740s] nsock_read(): Read request from IOD #2 [10.129.2.80:80] (timeout: 5000ms) EID 66
NSOCK INFO [7.9740s] nsock_trace_handler_callback(): Callback: WRITE SUCCESS for EID 59 [10.129.2.80:80]
NSOCK INFO [8.1860s] nsock_trace_handler_callback(): Callback: READ TIMEOUT for EID 42 [10.129.2.80:445]
Service scan sending probe SMBProgNeg to 10.129.2.80:445 (tcp)
NSOCK INFO [8.1860s] nsock_write(): Write request for 168 bytes to IOD #3 EID 75 [10.129.2.80:445]
NSOCK INFO [8.1860s] nsock_read(): Read request from IOD #3 [10.129.2.80:445] (timeout: 5000ms) EID 82
NSOCK INFO [8.1860s] nsock_trace_handler_callback(): Callback: WRITE SUCCESS for EID 75 [10.129.2.80:445]
NSOCK INFO [8.2430s] nsock_trace_handler_callback(): Callback: READ SUCCESS for EID 66 [10.129.2.80:80] (6670 bytes)
Service scan hard match (Probe GetRequest matched with GetRequest line 10693): 10.129.2.80:80 is http.  Version: |Apache httpd|2.4.29|(Ubunt
```

```
PORT    STATE SERVICE     REASON         VERSION
22/tcp  open  ssh         syn-ack ttl 63 OpenSSH 7.6p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
80/tcp  open  http        syn-ack ttl 63 Apache httpd 2.4.29 ((Ubuntu))
445/tcp open  netbios-ssn syn-ack ttl 63 Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
Service Info: Host: NIX-NMAP-EASY; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.37 seconds
```

Phase 2: IDS/IPS Hardened Environment Testing

Objective

Test effectiveness of updated IDS/IPS and firewall rules.

Observation

Port filtering increased after security improvements.

- Port 53/tcp (DNS) appeared filtered

Evasion Technique Used

UDP scanning with source port manipulation

Result

- DNS service confirmed via UDP
- Filtering bypass successful
- Service version identified

Impact

- IDS/IPS bypassed using UDP techniques
- Source port trust exploited
- Service fingerprinting still possible

Evidence

```
┌──(mehdi㉿kali)-[~/nmap_enum_Medium_Lab]
└─$ sudo nmap -sV -Pn -n 10.129.2.48 -p 53 --disable-arp-ping --packet-trace --source-port 53
[sudo] password for mehdi:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-19 09:07 EDT
SENT (0.1419s) TCP 10.10.15.50:53 > 10.129.2.48:53 S ttl=48 id=15590 iplen=44  seq=2540426036 win=1024 <mss 1460>
SENT (1.1428s) TCP 10.10.15.50:53 > 10.129.2.48:53 S ttl=50 id=17611 iplen=44  seq=2540294966 win=1024 <mss 1460>
Nmap scan report for 10.129.2.48
Host is up.

PORT   STATE    SERVICE VERSION
53/tcp filtered domain

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.26 seconds
```

```
┌──(mehdi㉿kali)-[~/nmap_enum_Medium_Lab]
└─$ sudo nmap -sU -Pn -n 10.129.2.48 -p 53 --disable-arp-ping --packet-trace --source-port 53
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-19 09:16 EDT
SENT (0.1078s) UDP 10.10.15.50:53 > 10.129.2.48:53 ttl=39 id=16843 iplen=58
SENT (0.1078s) UDP 10.10.15.50:53 > 10.129.2.48:53 ttl=38 id=16843 iplen=40
SENT (0.1078s) UDP 10.10.15.50:53 > 10.129.2.48:53 ttl=37 id=16843 iplen=74
RCVD (0.3514s) UDP 10.129.2.48:53 > 10.10.15.50:53 ttl=63 id=42118 iplen=115
Nmap scan report for 10.129.2.48
Host is up (0.24s latency).

PORT   STATE SERVICE
53/udp open  domain

Nmap done: 1 IP address (1 host up) scanned in 0.39 seconds
```

Phase 3: Newly Introduced Service Enumeration

Objective

Identify newly added or modified services after security updates.

Findings

- Port 50000/tcp open
- IBM DB2 database service detected

Technique Used

TCP scan and banner grabbing

Result

- Service banner successfully retrieved
- IBM DB2 version identified

Impact

- Sensitive database service exposed
- Version fingerprinting possible
- Attack surface increased

Evidence

```
┌──(mehdi㉿kali)-[~/nmap_enum_Hard_Lab]
└─$ sudo nmap -sV -Pn --disable-arp-ping 10.129.60.86
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-19 10:59 EDT
Stats: 0:00:07 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 2.10% done; ETC: 11:00 (0:01:33 remaining)
Nmap scan report for 10.129.60.86
Host is up (0.70s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE    SERVICE     VERSION
22/tcp    open     ssh         OpenSSH 7.6p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
80/tcp    open     http        Apache httpd 2.4.29 ((Ubuntu))
110/tcp   open     pop3        Dovecot pop3d
139/tcp   open     netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
143/tcp   open     imap        Dovecot imapd (Ubuntu)
445/tcp   open     netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
50000/tcp filtered ibm-db2
Service Info: Host: NIX-NMAP-HARD; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 41.36 seconds
```

```
┌──(mehdi㉿kali)-[~/nmap_enum_Hard_Lab]
└─$ ncat -nv --source-port 53 10.129.60.86 50000
Ncat: Version 7.98 ( https://nmap.org/ncat )
Ncat: Connected to 10.129.60.86:50000.
```

Attack Surface Summary

Phase	Finding	Severity
Phase 1	Multiple open services	High
Phase 2	IDS/IPS bypass via UDP	Critical
Phase 3	IBM DB2 exposed	Critical

Key Observations

- IDS/IPS improvements reduced visibility but did not stop reconnaissance
- UDP traffic is less strictly monitored
- Source port trust assumptions can be abused
- Database services remain externally identifiable

Recommendations

1. **IDS/IPS Hardening**
    - Enable deep packet inspection (DPI)
    - Detect spoofed source ports
    - Improve UDP monitoring

2. **Firewall Improvements**
    - Do not trust port-based assumptions (e.g., DNS 53)
    - Use strict stateful inspection

3. **Service Exposure Reduction**
    - Restrict database access (IBM DB2)
    - Limit service binding to internal networks

4. **Monitoring**
    - Detect scan patterns and anomalies
    - Log UDP + TCP hybrid scanning behavior

Conclusion

Although security improvements were applied after each test, the system still allows attackers to discover and identify critical services. Additional hardening is required to fully prevent reconnaissance and service fingerprinting.